

Unit 11 - Seminar Principles of Cybersecurity, Risk Management, and Ethical Hacking

1. Icebreaker Activity (10 minutes) – Cybersecurity in the News

My data was downloaded from BasicFit.

Data included: names, addresses, email addresses, telephone numbers, dates of birth, bank details and even the name of my mobile phone!

<https://www.vrt.be/vrtnws/en/2026/04/13/customer-data-hacked-both-at-basic-fit-and-booking-com/>

It affected 6 countries: the Netherlands, Belgium, France, Spain, Luxembourg and Germany.

Some report 200,000 customers, others over a million.

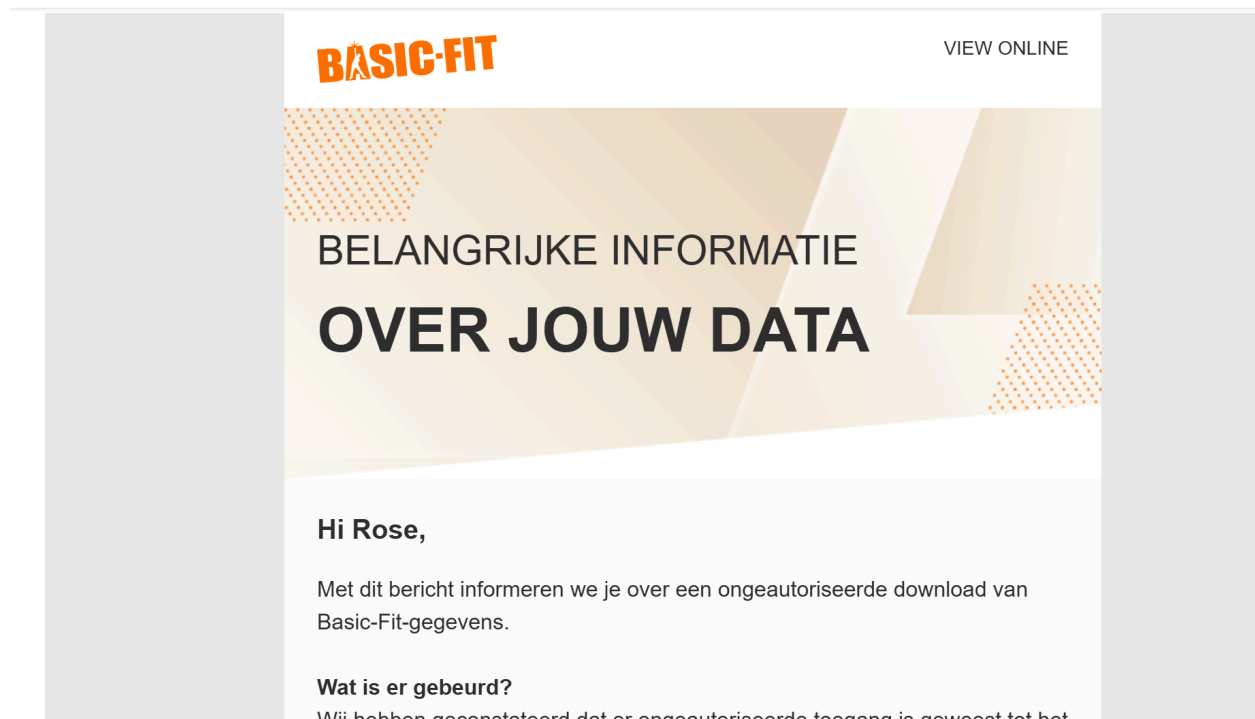
They attacked the centralized (international) system.

“The unauthorised access was detected by our system monitoring processes and was stopped within minutes of discovery” - Basic Fit in press statement

<https://corporate.basic-fit.com/docs/Basic-Fit%20informs%20members%20of%20an%20unauthorised%20data%20access?q=3W97qQx2g4cDXrju5NrDeZ>

[Booking.com](https://www.booking.com) (also dutch) was also targeted.

I was informed by email.



They also informed the Dutch Data Protection Authority within 72 hours. (Dutch based company).

How could it have been prevented?

As the data breach was a member visit/check-in related system, you can question if information on the user's bank account needs to be stored alongside the visiting information.

app-related health/body-analyzer data is kept in separate pseudonymized secured databases rather than in the member management system - maybe this would be a solution.

I am currently requesting more information so I can know more.

2. Cybersecurity Fundamentals and Risk Management

Interesting one on romance scams on Tinder with face recognition abuse:

<https://www.youtube.com/watch?v=rjxAYdUe8uU>

This technology is being used, but also abused. <https://www.facetec.com>

Phishing.

MitM attack - see report

3. Enterprise Risk Management (ERM):

Not hypothetical - my previous company.

Collected information on user desktop application settings.

This includes **drawing names** and **path files**. As such includes information such as "John Smiths' Computer" as part of the path name, or 10, Torrington Street Grimsby as part of the file name.

As such, access to this data was limited to the data team and was only given to the general company through powerbi dashboards.

This **caused conflicts in the company**. People wanted access to the raw data to do their own analysis, because they didn't trust the cleaning process or because they wanted to ask specific questions.

Conclusion:

Stakeholders didn't trust the data. Not cost effective, but was risk averse.

It was possible for data team members to identify individual users based on their data and their account information (stored separately).

As an additional layer of pain, the company had an office in Russia, but was owned by an American based company.

Case Study: How Equifax's 2017 data breach exposed 147 million customer records due to an unpatched vulnerability.

<https://www.justice.gov/archives/opa/pr/chinese-military-personnel-charged-computer-fraud-economic-espionage-and-wire-fraud-hacking>

209,000 consumers - largest at the time

3. Introduction to Ethical Hacking and Penetration Testing

(White hat) Ethical hackers are hired to try and mitigate security systems. For example, at an airport. Their job is to highlight weakness in the security system before other users do.

(Black hat) “the bad guys” - deliberately exploit companies and mine data.

(grey-hat) they break in without being asked, tell the company and then ask for a reward. Sometimes even being employed afterwards. It's a low-level way of advertising your skills.

(red-hat) the vigilant type. They use everything to bring down the black hat hackers. There are also some interesting red-hat AI hacking competitions going on.

Phases of Penetration Testing:

- Reconnaissance – Gathering information about the target system.
- Scanning – Identifying vulnerabilities and weak points.
- Exploitation – Testing the system for security flaws.
- Reporting – Documenting findings and recommending fixes.

Activity: Students will simulate a penetration test by analysing a dummy website's security vulnerabilities using open-source tools such as Nmap and Wireshark.

Example: How ethical hackers discovered a vulnerability in Facebook's login system and prevented a major data breach.

Cybersecurity Ethics and Legal Considerations

Students will explore the ethical challenges in cybersecurity and the legal boundaries of hacking.

Discussion Topics:

Is hacking ever justified?

Obviously, otherwise ethical hacking wouldn't exist...

If you are a spy, you may justify it for your own country's national security.

The ethics of government surveillance and AI-powered cyber defences.

Where do we draw the line between privacy and tracking?

As a parent I want to know where my children are, but I also want to give them trust and agency. At what age do I:

Take down the baby monitor

Stop tracking them on a tag or smart phone

Let them choose what to see on the internet

As a government, how do I draw the line at:

- Tracking movement of the population
- Tracking money transactions
- Health habits vs medical treatment
 - e.g. should non-exercisers be given treatments to illness that could be prevented through exercise?
 - Prevent people leaving the house during times of national health emergencies?
- Giving people a social number or rating based on their
 - Income
 - law abidingness
 - Habits
 - social circles
 - internet behaviour
 - Political beliefs

The risks of AI-powered deepfakes in cybersecurity.

Activity: Students will debate the following scenario: “A cybersecurity researcher discovers a vulnerability in a company’s payment system. Should they disclose it to the company or sell it on the dark web? Why?”

Idealised world, yes, they should report. However...

Companies might be considered unethical in themselves. For example, a vegan might believe they are doing right by exposing McDonald's and its customer base on the dark web, in the view of “animal rights”.

Or someone may expose Meta to a security threat that causes down time and lost earnings and trust to Meta or TikTok as they believe the company is harming young people in an addiction/attention way.

Example: The ethical dilemma of Apple’s bug bounty program, where hackers report security flaws for financial rewards rather than exploiting them.